

Cómo prepararse para una auditoría SOC 2

Guía práctica de preparación, controles, evidencia, pruebas y cumplimiento continuo

Autor: Alberto (Al) Leiva

Versión: 1.0 - Julio de 2026

Licencia: CC BY-NC-SA 4.0

Solo una firma CPA independiente y calificada puede emitir un informe SOC 2. Este manual es educativo y no sustituye la guía autorizada de AICPA ni el asesoramiento profesional.

Contenido

- 1. Comprender SOC 2
- 2. Informes Tipo 1 y Tipo 2
- 3. Gobierno y responsabilidad
- 4. Definir el alcance y los límites
- 5. Criterios de Servicios de Confianza y mapeo
- 6. Evaluación de riesgos
- 7. Políticas y estándares
- 8. Controles de acceso lógico
- 9. Gestión de cambios y desarrollo seguro
- 10. Operaciones de seguridad e incidentes
- 11. Disponibilidad y continuidad
- 12. Confidencialidad, privacidad y ciclo de datos
- 13. Proveedores y suborganizaciones
- 14. Gestión de evidencia
- 15. Población, muestreo y excepciones
- 16. Descripción del sistema
- 17. Trabajo con el auditor
- 18. Fallas frecuentes
- 19. Plan de 30/60/90 días
- 20. Lista final y proyecto de portafolio

1. Comprender SOC 2

SOC 2 es un examen de controles en una organización de servicios relacionados con seguridad, disponibilidad, integridad del procesamiento, confidencialidad o privacidad. El auditor de servicios realiza el examen; la gerencia prepara la descripción del sistema, formula las afirmaciones, es propietaria de los controles y proporciona evidencia. SOC 2 no es una certificación de producto ni un escaneo técnico aislado.

- Seguridad es el criterio común y forma parte de todo examen SOC 2.
- Disponibilidad, integridad del procesamiento, confidencialidad y privacidad se seleccionan cuando son pertinentes.
- El alcance debe reflejar los servicios, componentes, ubicaciones, personas, procesos, datos y suborganizaciones relevantes.

2. Informes Tipo 1 y Tipo 2

Un informe Tipo 1 aborda el diseño y la implementación de controles en una fecha determinada. Un Tipo 2 también aborda la eficacia operativa durante un período definido. Los clientes suelen solicitar Tipo 2 porque ofrece evidencia de operación sostenida.

- Seleccione el tipo según las necesidades del cliente, la madurez, el historial disponible y la orientación del auditor.
- No afirme que un control operó durante un período sin evidencia completa y consistente.
- Reserve tiempo para corregir brechas antes de iniciar el período.

3. Gobierno y responsabilidad

La preparación SOC 2 es un programa transversal. Seguridad puede coordinarlo, pero la operación y la evidencia suelen depender de ingeniería, TI, recursos humanos, legal, privacidad, finanzas, instalaciones, operaciones y liderazgo ejecutivo.

- Nombre patrocinador ejecutivo, líder del programa, propietarios de controles, proveedores de evidencia y responsables de corrección.
- Cree una matriz RACI y reuniones periódicas.
- Escale pronto la evidencia faltante, las correcciones vencidas y los cambios de alcance.

4. Definir el alcance y los límites

Un alcance defendible comienza con los compromisos de servicio y el sistema utilizado para cumplirlos. No limite el alcance a la aplicación de producción ignorando identidades, nube, soporte, canalizaciones, monitoreo o proveedores clave.

- Documente productos y servicios incluidos.
- Identifique infraestructura, software, personas, procedimientos y datos.
- Defina límites físicos y lógicos.
- Identifique suborganizaciones y acuerde el método de presentación.
- Documente controles complementarios que deben ejecutar los clientes.

5. Criterios de Servicios de Confianza y mapeo

Mapee riesgos y controles a los criterios aplicables sin tratarlos como una lista de tecnologías obligatorias. Los controles deben responder a los riesgos, compromisos y requisitos reales.

- Comience con riesgos y compromisos.
- Mapee cada control y explique la relación.

- Evite duplicados artificiales.
- Use los puntos de enfoque como consideraciones, no como controles independientes obligatorios.

6. Evaluación de riesgos

El programa necesita un proceso documentado para identificar objetivos, amenazas, vulnerabilidades, fraude, cambios, terceros e impactos. La evaluación debe orientar el diseño de controles y actualizarse ante cambios materiales.

- Defina criterios y propietarios.
- Conecte riesgos con controles y tratamientos.
- Incluya nube, identidad, cadena de suministro, privacidad, disponibilidad y riesgo interno.
- Registre riesgos aceptados y aprobación de la gerencia.

7. Políticas y estándares

Las políticas establecen expectativas; los estándares y procedimientos explican cómo se trabaja. Una política no comunicada, aprobada, revisada ni respaldada por evidencia es débil.

- Mantenga versión, propietario, aprobador, vigencia y revisión.
- Capacite al personal afectado.
- Conecte declaraciones con controles implementados.
- Elimine documentos obsoletos o contradictorios.

8. Controles de acceso lógico

Los controles deben cubrir usuarios, privilegiados, cuentas de servicio, aplicaciones, agentes, contratistas y terceros durante todo el ciclo de vida.

- Documente altas, cambios y bajas.
- Exija autenticación fuerte y proteja privilegios.
- Revise el acceso periódicamente.
- Monitoree cuentas inactivas, compartidas, de emergencia y no humanas.
- Conserve solicitudes, aprobaciones, provisión, revisiones y retiros.

9. Gestión de cambios y desarrollo seguro

Los cambios deben demostrar autorización, pruebas, revisión, trazabilidad y separación adecuada de funciones.

- Use tickets o pull requests aprobados.
- Proteja ramas y credenciales de despliegue.
- Documente cambios de emergencia y revisión posterior.
- Conecte corrección de vulnerabilidades con registros de cambio.
- Conserve evidencia de despliegue durante todo el período.

10. Operaciones de seguridad e incidentes

Monitoreo, vulnerabilidades, triaje, respuesta y lecciones aprendidas deben funcionar como un proceso conectado.

- Defina severidad y escalamiento.
- Conserve escaneos, correcciones, alertas, casos, cronologías y revisiones.
- Pruebe el plan de respuesta.
- Rastree problemas recurrentes y acciones correctivas.

11. Disponibilidad y continuidad

Cuando disponibilidad está en alcance, los controles deben abordar capacidad, resiliencia, copias, recuperación, monitoreo y compromisos de continuidad.

- Defina objetivos de recuperación.
- Pruebe restauración, no solo finalización de copias.
- Ejercite continuidad y recuperación.
- Documente incidentes, caídas, capacidad y correcciones.

12. Confidencialidad, privacidad y ciclo de datos

Confidencialidad protege información designada como confidencial. Privacidad aborda información personal desde su recopilación hasta su eliminación. Se relacionan, pero no son equivalentes.

- Inventarie datos sensibles y personales.
- Defina clasificación, retención, eliminación, cifrado y acceso.
- Revise acuerdos de intercambio y subprocesadores.
- Documente avisos, opciones, solicitudes e incidentes cuando privacidad esté en alcance.

13. Proveedores y suborganizaciones

La organización debe comprender sus dependencias de proveedores de nube, procesadores, soporte y otras suborganizaciones.

- Realice diligencia debida basada en riesgo.
- Revise contratos y compromisos.
- Obtenga y evalúe informes de aseguramiento.
- Rastree controles complementarios.
- Monitoree cambios, incidentes, desempeño y terminación.

14. Gestión de evidencia

La buena evidencia es pertinente, completa, exacta, atribuible, delimitada en el tiempo y protegida contra alteración. Las capturas solas suelen ser insuficientes.

- Defina requisitos antes del período.

- Conserve poblaciones y exportaciones generadas por sistemas.
- Registre fuente, propietario, fecha, alcance y revisor.
- Proteja evidencia confidencial.
- Use nombres consistentes e índice de evidencia.

15. Población, muestreo y excepciones

Para controles recurrentes, el auditor puede seleccionar muestras de una población completa. La gerencia debe producir la población y explicar su generación.

- Reconcilie conteos con sistemas fuente.
- No elimine elementos fallidos.
- Investigue excepciones y causa raíz.
- Distinga brechas de evidencia de fallas de control.
- Documente corrección y pruebas adicionales.

16. Descripción del sistema

La gerencia prepara la descripción del sistema. Debe ser exacta, equilibrada y consistente con las operaciones y compromisos reales.

- Describa servicios, límites, infraestructura, software, personas, procedimientos, datos y eventos.
- Explique criterios, controles, suborganizaciones y controles de usuarios.
- Evite lenguaje comercial exagerado.
- Actualice ante cambios.

17. Trabajo con el auditor

Seleccione una firma CPA calificada con experiencia sectorial y tecnológica. Acuerde alcance, calendario, criterios, tipo, tratamiento de terceros, hitos, métodos de evidencia y comunicación.

- Proporcione información exacta y revele incidentes o fallas conocidas.
- Aclare solicitudes temprano.
- Rastree solicitudes, preguntas, excepciones y respuestas.
- La gerencia es responsable de la preparación; el auditor debe ser independiente.

18. Fallas frecuentes

Problemas comunes incluyen alcance impreciso, poblaciones faltantes, controles solo en políticas, aprobaciones inconsistentes, evidencia creada después, acceso obsoleto, recuperación no probada y afirmaciones sin respaldo.

- Realice evaluación previa.
- Ejecute simulaciones de recopilación.
- Pruebe controles antes de depender de ellos.
- Administre cambios formalmente.

- Trate excepciones repetidas como problemas sistémicos.

19. Plan de 30/60/90 días

Una hoja de ruta práctica ayuda a convertir controles fragmentados en un modelo auditable.

- Días 1-30: confirmar necesidad, alcance preliminar, propietarios, inventario, compromisos y brechas críticas.
- Días 31-60: finalizar matriz, corregir brechas, crear procedimientos de evidencia, redactar descripción y hacer pruebas simuladas.
- Días 61-90: operar controles, resolver excepciones, validar poblaciones y confirmar fechas con el auditor.

20. Lista final y proyecto de portafolio

La decisión de preparación debe basarse en evidencia. Como proyecto seguro, el estudiante puede crear una organización ficticia, alcance, registro de riesgos, matriz de controles, índice de evidencia, revisión de acceso, ejercicio de incidentes y esquema de descripción.

- Nunca publique evidencia real, datos de empleados, capturas de producción, secretos ni papeles de trabajo de auditoría.
- Marque claramente los artefactos ficticios.
- Explique supuestos, limitaciones y cómo cada control reduce un riesgo.

Referencias oficiales

- [Descripción general de AICPA sobre SOC para organizaciones de servicios](#)
- [Recursos de AICPA sobre SOC 2](#)
- [Guía de AICPA sobre informes SOC 2](#)